Algoritmi e Protocolli per la Sicurezza

Project Work

WP2: Soluzione proposta

Protocollo per voto elettronico con separazione tra autenticazione, autorizzazione, raccolta e scrutinio

Autori: Gennaro Foschillo
Francesco Vittorio Allocca

A.A. 2025–2026

Indice

1 WP2: Soluzione proposta **1**

1.1 Glossario e notazione . . . 1

1.1.1 Entità principali . . . 1

1.1.2 Chiavi e certificati . . . 1

1.1.3 Oggetti elettorali e registri . . . 2

1.1.4 Token di autorizzazione . . . 3

1.1.5 Primitive e operatori . . . 3

1.1.6 Scrutiny Authority distribuita . . . 4

1.1.7 Convenzioni sui messaggi . . . 4

1.1.8 Distinzioni terminologiche . . . 4

1.2 Obiettivo del Work Package . . . 4

1.3 Entità del protocollo e informazioni gestite . . . 5

1.3.1 Government Authority (GA) . . . 5

1.3.2 Voting Client (VC) . . . 6

1.3.3 Voting Server (VS) . . . 8

1.3.4 Registro Elettorale / Bulletin Board (ER) . . . 9

1.3.5 Scrutiny Authority (SA) . . . 9

1.4 Primitive crittografiche adottate . . . 10

1.5 Setup iniziale e infrastruttura di fiducia . . . 12

1.5.1 Premessa sui canali di comunicazione sicuri . . . 12

1.5.2 Generazione delle chiavi infrastrutturali . . . 13

1.5.3 Preparazione della Scrutiny Authority distribuita . . . 13

1.5.4 Richiesta di accreditamento . . . 14

1.5.5 Verifica della richiesta da parte della Government Authority . . . 14

1.5.6 Emissione dei certificati . . . 15

1.5.7 Pubblicazione del manifesto dell'elezione . . . 15

1.5.8 Pubblicazione e aggiornamento della lista di revoca . . . 16

1.5.9 Revoca dell'accreditamento . . . 17

1.6 Flusso generale del protocollo . . . 18

1.7 Fase 1: inizializzazione del Voting Client . . . 18

1.8 Fase 2: autenticazione dell'elettore 19
1.9 Fase 3: verifica dell'idoneità e rilascio del token 20
1.10 Fase 4: preparazione locale della scheda 20
1.11 Fase 5: verifica del Voting Server e apertura del canale sicuro 21
1.12 Fase 6: invio della busta di voto e verifica del token 23
1.13 Fase 7: registrazione del token speso 23
1.14 Fase 8: pubblicazione sul Registro Elettorale / Bulletin Board 24
1.15 Fase 9: chiusura delle urne e scrutinio finale 26
1.16 Fase 10: pubblicazione del risultato e verificabilità 26
1.16.1 Verificabilità individuale 27
1.16.2 Verificabilità universale 27

1 WP2: Soluzione proposta

1.1 Glossario e notazione

Questa sezione introduce la notazione usata nel protocollo. Le definizioni sono volutamente sintetiche in questa parte, in quanto verranno poi specificate nelle sezioni successive. Nel seguito si considera una specifica istanza elettorale identificata da $ID_{Election}$.

1.1.1 Entità principali

Simbolo	Descrizione
U	Elettore che partecipa alla consultazione.
VC	Voting Client usato dall'elettore per autenticarsi, ottenere il token, compilare la scheda e inviare il voto.
GA	Government Authority responsabile di autenticazione, verifica di idoneità, rilascio dei token, certificazione delle entità e pubblicazione dei parametri elettorali.
IP	Identity Provider Module della GA, incaricato dell'autenticazione dell'elettore.
CA	Certification Authority Module della GA, incaricato di emettere e revocare i certificati delle entità infrastrutturali.
EV	Eligibility Verification Module della GA, incaricato di verificare il diritto al voto dell'elettore autenticato.
VTI	Voting Token Issuer Module della GA, incaricato di emettere token di autorizzazione al voto.
VS	Voting Server che verifica i token ricevuti, accetta le schede cifrate valide e le inoltra al Registro Elettorale.
ER	Registro Elettorale / Bulletin Board append-only che conserva e pubblica le schede cifrate accettate.
SA	Scrutiny Authority incaricata dello scrutinio finale. Nel protocollo è modellata come autorità distribuita.
SA_i	Nodo fiduciario della Scrutiny Authority distribuita, con $i \in \{1, \ldots, n\}$.

1.1.2 Chiavi e certificati

Con pk_X e sk_X si indicano rispettivamente la chiave pubblica e la chiave privata dell'entità X.

Simbolo	Descrizione
(pk_{GA}, sk_{GA})	Coppia di chiavi della Government Authority. sk_{GA} firma certificati, token, manifesto e CRL; pk_{GA} verifica tali firme.

Simbolo	Descrizione
(pk_{VS}, sk_{VS})	Coppia di chiavi del Voting Server. pk_{VS} è inclusa in $Cert_{VS}$; sk_{VS} autentica il server e firma eventuali messaggi verso ER o VC.
(pk_{ER}, sk_{ER})	Coppia di chiavi del Registro Elettorale. sk_{ER} firma record, stati del registro o ricevute di inclusione.
pk_{SA}	Chiave pubblica elettorale usata dal Voting Client per cifrare la preferenza.
sk_{SA}	Chiave privata elettorale associata a pk_{SA}. Non è detenuta da una singola entità, ma frammentata tra i nodi della SA.
sk_{SA_i}	Frammento privato detenuto dal nodo fiduciario SA_i.
(pk_U, sk_U)	Coppia di chiavi dell'elettore per la specifica elezione. pk_U vincola il token; sk_U resta nel client o nel wallet locale.
$Cert_X$	Certificato digitale dell'entità X, firmato dalla GA. Associa chiave pubblica, identità, ruolo e istanza elettorale.
$Cert_{VS}$	Certificato del Voting Server.
$Cert_{ER}$	Certificato del Registro Elettorale.
$Cert_{SA_i}$	Certificato del nodo fiduciario SA_i.

1.1.3 Oggetti elettorali e registri

Simbolo	Descrizione
$ID_{Election}$	Identificativo univoco dell'elezione.
$Params_{Election}$	Manifesto pubblico dell'elezione: contiene identificativo, opzioni, tempi, certificati, pk_{SA}, parametri della SA distribuita, versione, timestamp e firma della GA.
$CRL_{Election}$	Lista dei certificati revocati per l'elezione, firmata dalla GA.
$EligibleEntitiesDB$	Registro interno della GA con le entità infrastrutturali accreditabili.
$EligibleUsersDB$	Registro interno della GA con gli elettori aventi diritto.
$IssuedTokensDB$	Registro interno della GA con i token emessi e il relativo stato.
$SpentTokensDB$	Registro interno del VS usato per rilevare il riuso dei token senza salvarli in chiaro.
$Options$	Insieme delle opzioni ammesse. Nel caso base: $Options = \{\text{Sì}, \text{No}\}$.
v	Preferenza selezionata dall'elettore, con $v \in Options$.
$EncVoto_{SA}$	Voto cifrato con pk_{SA}.
$Ballot$	Busta logica di voto inviata dal Voting Client al Voting Server.
$BoardRecord_i$	Record pubblicato dal Registro Elettorale per la scheda cifrata i-esima.

Simbolo	Descrizione
$Leaf_i$	Hash della scheda cifrata o del relativo record, usato per la verifica di inclusione.
$Root_{final}$	Radice finale della struttura pubblicata dal Registro Elettorale alla chiusura delle urne.
$Receipt_U$	Ricevuta usata dall'elettore per verificare l'inclusione della propria scheda cifrata.

1.1.4 Token di autorizzazione

Simbolo	Descrizione
$SerialNumber_{Token}$	Identificativo univoco del token generato dalla GA.
$Permit_U$	Permesso di voto: contiene almeno $ID_{Election}$, $SerialNumber_{Token}$, pk_U ed eventuale scadenza. Non contiene la preferenza.
σ_{GA}^{Permit}	Firma della GA sul permesso $Permit_U$.
$VotingToken_U$	Token firmato: $VotingToken_U = (Permit_U, \sigma_{GA}^{Permit})$.
$EncToken_U$	Token cifrato dalla GA verso il Voting Client usando pk_U.
$EncToken_{VS}$	Token cifrato dal Voting Client verso il Voting Server usando pk_{VS}.
$Salt_i$	Sale dinamico derivato dal VS per la transazione i-esima.
K_{Master_Server}	Segreto interno del VS usato per derivare i sali dinamici.
$Hash_{Spent}$	Digest memorizzato in $SpentTokensDB$ per riconoscere token già usati.

1.1.5 Primitive e operatori

Notazione	Descrizione
$H(m)$	Hash crittografico del messaggio m.
$Sign_{sk_X}(H(m))$	Firma digitale prodotta da X sul digest di m.
$Verify_{pk_X}(m, \sigma)$	Verifica della firma σ tramite la chiave pubblica pk_X.
$Enc_{pk_X}(m)$	Cifratura asimmetrica di m per l'entità X.
$Dec_{sk_X}(c)$	Decifratura del ciphertext c tramite sk_X.
$MAC_k(m)$	Codice di autenticazione del messaggio m tramite chiave simmetrica k.
$\|$	Concatenazione ordinata di campi.
$nonce$	Valore casuale monouso usato per freschezza e anti-replay.
$timestamp$	Istante temporale associato a messaggi, certificati o liste di revoca.
$k_{session}$	Chiave simmetrica di sessione stabilita tramite canale sicuro autenticato.

Notazione	Descrizione
k_{enc}, k_{mac}	Sotto-chiavi derivate da $k_{session}$ per cifratura e autenticazione del canale.

1.1.6 Scrutiny Authority distribuita

Simbolo	Descrizione
n	Numero totale di nodi fiduciari della Scrutiny Authority.
k	Numero minimo di nodi necessari per completare lo scrutinio distribuito, con $1 \leq k \leq n$.
$\langle k, n \rangle$	Parametri della Scrutiny Authority distribuita.
$Share_i$	Frammento privato associato al nodo SA_i.
$DecShare_i$	Contributo di decifratura prodotto dal nodo SA_i su una scheda cifrata.
$TallyBoard$	Bacheca finale pubblicata per rendere verificabile lo scrutinio.

1.1.7 Convenzioni sui messaggi

I messaggi del protocollo sono indicati nella forma:

$$M_j : A \to B : (campo_1, campo_2, \ldots, campo_n)$$

dove M_j identifica il messaggio, A è il mittente e B è il destinatario.

Una firma viene indicata come:

$$\sigma_X = Sign_{sk_X}(H(m))$$

mentre una cifratura per il destinatario Y viene indicata come:

$$Enc_{pk_Y}(m).$$

1.1.8 Distinzioni terminologiche

Nel documento, *autenticazione* indica la verifica dell'identità di un elettore o di un'entità infrastrutturale. *Autorizzazione* indica invece il rilascio del diritto a votare per una specifica elezione.

La *segretezza del voto* riguarda la protezione della preferenza. Il *pseudoanonimato* riguarda la separazione tra identità reale e scheda nelle fasi di raccolta, registrazione e scrutinio.

La *verificabilità individuale* permette al singolo elettore di controllare l'inclusione della propria scheda cifrata. La *verificabilità universale* permette a osservatori esterni di controllare la coerenza tra schede pubblicate, scrutinio e risultato finale.

1.2 Obiettivo del Work Package

In questo Work Package viene descritta la soluzione proposta a partire dal modello logico definito nel WP1. La soluzione è progettata per un referendum binario, in cui l'elettore

può esprimere una preferenza tra le opzioni ammesse dalla consultazione. Questa scelta riduce la complessità della scheda, semplifica la fase di scrutinio e consente di concentrare la progettazione sui meccanismi di autenticazione, autorizzazione, segretezza del voto, integrità della registrazione e verificabilità del risultato.

L'obiettivo principale è definire un protocollo che realizzi un compromesso ragionevole tra autenticità, unicità, segretezza, pseudoanonimato, integrità, verificabilità individuale, verificabilità universale ed efficienza. La soluzione ha come obiettivo quello di separare quanto più' possibile le informazioni trattate dalle varie componenti, evitando associazioni dirette identità-voto.

In particolare, il protocollo specifica le azioni sequenziali eseguite dalle parti oneste, le chiavi e i certificati utilizzati dalle entità infrastrutturali, il formato logico dei principali messaggi scambiati, il meccanismo di autenticazione dell'elettore e di rilascio del token di autorizzazione, la preparazione e registrazione della scheda cifrata, la procedura di scrutinio finale e i meccanismi di verificabilità individuale e universale.

1.3 Entità del protocollo e informazioni gestite

In questa sezione vengono descritte le principali entità coinvolte nel protocollo proposto. Per ciascuna entità vengono specificati il ruolo svolto, le chiavi possedute, le informazioni gestite e i dati che non devono essere conosciuti per preservare la separazione tra identità reale, autorizzazione al voto e preferenza espressa.

1.3.1 Government Authority (GA)

Descrizione. La Government Authority rappresenta l'autorità istituzionale responsabile della gestione dell'elezione dal punto di vista dell'identificazione degli elettori, dell'autorizzazione al voto e della fiducia infrastrutturale. Nel protocollo proposto è modellata come un'unica entità composta da più moduli logici interni, ciascuno associato a una specifica responsabilità.

Moduli logici. La Government Authority include i seguenti moduli:

- **Identity Provider Module (IP):** identifica e autentica l'elettore che richiede di partecipare all'elezione. Il modulo verifica che l'utente sia effettivamente il soggetto dichiarato, utilizzando un meccanismo di identità digitale riconosciuto dalla Government Authority.
- **Certification Authority Module (CA):** certifica le entità infrastrutturali autorizzate a partecipare al protocollo, cioè Voting Server, Registro Elettorale e nodi fiduciari della Scrutiny Authority. Il modulo rilascia certificati digitali che associano una chiave pubblica a un'identità infrastrutturale, a un ruolo operativo e a una specifica elezione. Inoltre, mantiene le informazioni relative ai certificati emessi e revocati.
- **Eligibility Verification Module (EV):** verifica che un elettore autenticato sia effettivamente avente diritto al voto per l'elezione considerata. Questo modulo utilizza il registro degli aventi diritto e non tratta informazioni relative alla preferenza di voto.

- **Voting Token Issuer Module (VTI):** rilascia token di autorizzazione unici e validi per una specifica elezione che permettono all' elettore di accedere alla compilazione della scheda. I token vengono associati internamente all'identità reale dell'elettore, ma tale associazione rimane confinata nella Government Authority.

La Government Authority è inoltre responsabile della pubblicazione dei parametri pubblici dell'elezione, indicati come $Params_{Election}$, e della lista dei certificati revocati, indicata come $CRL_{Election}$.

Chiavi. La Government Authority possiede una coppia di chiavi di firma (pk_{GA}, sk_{GA}). La chiave privata sk_{GA} viene utilizzata per firmare certificati digitali, token di autorizzazione, parametri pubblici dell'elezione e liste di revoca. La chiave pubblica pk_{GA} viene utilizzata dalle altre entità per verificare gli oggetti firmati dalla Government Authority.

Dati che conosce. La Government Authority conosce l'identità reale dell'elettore durante le fasi di identificazione, autenticazione e verifica dell'idoneità. Riceve inoltre la chiave pubblica pk_U, generata dal Voting Client per la specifica elezione, al solo scopo di vincolare il token di autorizzazione al possesso della corrispondente chiave privata sk_U. La Government Authority conosce anche le identità delle entità infrastrutturali che richiedono un certificato e le rispettive chiavi pubbliche.

Dati che non deve conoscere. La Government Authority non deve conoscere la preferenza espressa dall'elettore e non deve ricevere la scheda cifrata. La sua interazione con l'elettore termina con il rilascio dell'autorizzazione al voto.

1.3.2 Voting Client (VC)

Descrizione. Il Voting Client è l'applicazione ufficiale attraverso cui l'elettore interagisce con il sistema di voto. Permette all'utente di accedere all'istanza elettorale, avviare la fase di autenticazione presso la Government Authority, ottenere il token di autorizzazione, compilare la scheda e inviare il voto.

Assunzione operativa sul client. Per la soluzione proposta si assume che il Voting Client sia ottenuto da un canale ufficiale della Government Authority, ad esempio portale istituzionale, store verificato o repository ufficiale, e che il pacchetto applicativo sia firmato dalla Government Authority. Prima dell'uso, l'elettore o il sistema operativo possono verificare l'autenticità del pacchetto applicativo tramite la firma della GA. Questa assunzione riduce il rischio di installazione di un client falso, ma non elimina il rischio di compromissione del dispositivo dell'utente.

Ruolo. Il Voting Client svolge le seguenti funzioni principali:

- recupera e verifica $Params_{Election}$ e $CRL_{Election}$;
- verifica i certificati delle entità, cioè $Cert_{VS}$, $Cert_{ER}$ e i certificati dei nodi fiduciari della Scrutiny Authority;
- genera o recupera una coppia di chiavi (pk_U, sk_U) valida per la specifica elezione $ID_{Election}$;
- richiede alla Government Authority il token di autorizzazione;

- verifica localmente il token ricevuto, controllando la firma della Government Authority, l'identificativo dell'elezione, la validità temporale e il legame con pk_U;
- mostra all'elettore le opzioni previste dalla consultazione;
- cifra la preferenza utilizzando la chiave pubblica elettorale della Scrutiny Authority;
- firma la richiesta di voto con sk_U, dimostrando il possesso della chiave privata associata al token;
- verifica il certificato del Voting Server e apre un canale sicuro autenticato;
- invia al Voting Server la scheda cifrata e il token di autorizzazione;
- riceve una prova di inclusione utile alla verificabilità individuale.

Chiavi. Il Voting Client non possiede chiavi permanenti valide per più elezioni. Per ogni elezione genera o recupera una coppia di chiavi (pk_U, sk_U) associata a $ID_{Election}$. La chiave pubblica pk_U viene comunicata alla Government Authority durante la richiesta di autorizzazione ed è inserita nel token firmato. La chiave privata sk_U rimane sul dispositivo dell'utente, preferibilmente in uno storage locale protetto o wallet, e viene utilizzata per dimostrare il possesso della chiave associata al token.

Il Voting Client utilizza inoltre le chiavi pubbliche delle entità infrastrutturali, estratte dai rispettivi certificati, per verificare firme, validare il Voting Server e cifrare la scheda verso la Scrutiny Authority.

Relazione con il canale sicuro. L'apertura del canale sicuro con il Voting Server non richiede che il client sia pienamente fidato. Essa richiede che il client verifichi correttamente $Cert_{VS}$, controlli la $CRL_{Election}$ e partecipi a un key exchange autenticato, ad esempio basato su Diffie-Hellman autenticato dal certificato del server. Il risultato di questa fase è una chiave di sessione $k_{session}$, usata dallo strato di comunicazione per proteggere i messaggi in transito.

Il canale sicuro garantisce che un avversario esterno non possa sostituirsi al Voting Server, leggere o modificare la busta di voto durante la trasmissione o riutilizzare messaggi di sessioni precedenti. Tuttavia, se il client locale è già malevolo o il dispositivo è compromesso, il canale sicuro non impedisce la manipolazione prima dell'invio. Per questo motivo, la sicurezza del protocollo non viene fondata sulla piena fiducia nel client, ma sulla combinazione tra distribuzione ufficiale del software, verifiche crittografiche, cifratura end-to-end della scheda verso la Scrutiny Authority e verificabilità successiva dell'inclusione.

Dati che conosce e gestisce temporaneamente. Durante il protocollo, il Voting Client può trattare $Params_{Election}$, $CRL_{Election}$, i certificati delle entità operative, $ID_{Election}$, il token di autorizzazione ricevuto, la coppia (pk_U, sk_U), la preferenza selezionata prima della cifratura, la scheda cifrata e la ricevuta di inclusione.

Dati che non deve conservare stabilmente. Il Voting Client non deve conservare stabilmente informazioni che permettano di collegare identità reale, token di autorizzazione e preferenza espressa. Dopo il completamento della votazione, non deve mantenere la preferenza in chiaro o log locali contenenti dati utili a ricostruire il legame tra elettore e voto.

Rischio residuo. Un client compromesso può alterare la preferenza prima della cifratura, mostrare all'elettore un'interfaccia ingannevole o conservare dati locali utili alla coercizione. Il protocollo può mitigare questi rischi tramite distribuzione ufficiale del client, verifica della firma del pacchetto applicativo, uso di canali sicuri e verificabilità individuale dell'inclusione, ma non può eliminarli completamente in un contesto di voto remoto non presidiato.

1.3.3 Voting Server (VS)

Descrizione. Il Voting Server, dopo essere stato certificato dalla Government Authority, è incaricato di ricevere le schede cifrate inviate dal Voting Client e di verificarne l'autorizzazione tramite il token di voto. Il Voting Server verifica che il token sia valido, firmato dalla Government Authority, riferito all'elezione corrente e non già utilizzato. È inoltre responsabile dell'inoltro delle schede accettate al Registro Elettorale.

Il Voting Server non autentica direttamente l'identità reale dell'elettore e non decide l'idoneità alla partecipazione. Tali funzioni sono svolte dalla Government Authority. Inoltre, non deve conoscere la preferenza in chiaro, poiché riceve solo schede cifrate per la Scrutiny Authority.

Ruolo. Il Voting Server svolge le seguenti funzioni principali:

- presenta il proprio certificato digitale $Cert_{VS}$ al Voting Client;
- partecipa alla creazione di un canale sicuro con il Voting Client;
- verifica firma, validità e scadenza del token di autorizzazione;
- verifica che il token sia valido per $ID_{Election}$;
- verifica che il token non sia già stato utilizzato;
- registra un riferimento non invertibile al token nel registro dei token spesi;
- inoltra al Registro Elettorale la scheda cifrata validata;
- riceve dal Registro Elettorale una ricevuta di inclusione e la inoltra al Voting Client.

Chiavi. Il Voting Server possiede una coppia di chiavi (pk_{VS}, sk_{VS}). La chiave pubblica pk_{VS} è contenuta nel certificato digitale $Cert_{VS}$, rilasciato e firmato dalla Government Authority. La chiave privata sk_{VS} viene utilizzata per autenticarsi durante l'apertura del canale sicuro e, ove previsto, per firmare messaggi destinati al Registro Elettorale o ricevute inoltrate al Voting Client.

Dati che conosce e gestisce. Durante il protocollo, il Voting Server può conoscere il proprio certificato, $Params_{Election}$, $CRL_{Election}$, i token di autorizzazione ricevuti, lo stato dei token già utilizzati, le schede cifrate ricevute, metadati tecnici di sessione e riferimenti ai record pubblicati sul Registro Elettorale.

Per ridurre l'esposizione dei token in caso di compromissione del database, il Voting Server non conserva il token in chiaro nel registro dei token spesi. Conserva invece un valore derivato mediante hash e sale dinamico, sufficiente a riconoscere deterministicamente eventuali riutilizzi dello stesso token.

Dati che non deve conoscere. Il Voting Server non deve conoscere l'identità reale dell'elettore e non deve conoscere la preferenza in chiaro. Può verificare che un token valido sia stato utilizzato, ma non deve poter ricondurre tale token all'identità reale dell'elettore.

1.3.4 Registro Elettorale / Bulletin Board (ER)

Descrizione. Il Registro Elettorale, indicato anche come Bulletin Board, è l'entità incaricata di conservare e pubblicare le schede cifrate accettate dal Voting Server. Nel protocollo proposto viene modellato come un registro append-only, cioè una struttura in cui è possibile aggiungere record, ma non modificarli o rimuoverli senza che l'alterazione risulti rilevabile.

Il Registro Elettorale non autentica gli elettori, non verifica l'idoneità al voto e non decifra le schede ricevute. La sua funzione è rendere pubblicamente verificabile l'insieme dei voti accettati, supportando sia la verificabilità individuale sia la verificabilità universale.

Ruolo. Il Registro Elettorale svolge le seguenti funzioni principali:

- riceve dal Voting Server le schede cifrate che hanno superato i controlli;
- registra ogni scheda accettata in un record append-only;
- calcola le impronte crittografiche dei record;
- collega i record mediante hash pointer o struttura Merkle-based;
- produce una ricevuta o prova di inclusione;
- rende pubblici i dati necessari alla verifica individuale e universale;
- fornisce, a chiusura dell'elezione, l'insieme dei voti cifrati alla Scrutiny Authority.

Chiavi. Il Registro Elettorale possiede una coppia di chiavi (pk_{ER}, sk_{ER}). La chiave pubblica pk_{ER} è contenuta nel certificato digitale $Cert_{ER}$, rilasciato e firmato dalla Government Authority. La chiave privata sk_{ER} può essere utilizzata per firmare record pubblicati, ricevute di inclusione o stati del registro. Il certificato $Cert_{ER}$, invece, è firmato dalla Government Authority e non dal Registro Elettorale stesso.

Dati che conosce e gestisce. Durante il protocollo, il Registro Elettorale può conoscere il proprio certificato, $Params_{Election}$, $CRL_{Election}$, le schede cifrate accettate dal Voting Server, gli identificativi dei record pubblicati, i timestamp di registrazione, gli hash dei record, le ricevute o prove di inclusione ed eventuali firme del Voting Server.

Dati che non deve conoscere. Il Registro Elettorale non deve conoscere l'identità reale dell'elettore, il token associato all'identità reale e la preferenza in chiaro. Esso conserva solo informazioni pubblicabili relative alle schede cifrate e alla loro inclusione nel registro.

1.3.5 Scrutiny Authority (SA)

Descrizione. La Scrutiny Authority è l'entità incaricata di eseguire lo scrutinio finale dell'elezione. Interviene solo dopo la chiusura delle urne e opera sui voti cifrati pubblicati nel Registro Elettorale. Non partecipa alla fase di identificazione, non verifica l'idoneità, non rilascia autorizzazioni e non riceve le schede direttamente dal Voting Client.

Nel protocollo proposto, la Scrutiny Authority è modellata come un insieme di nodi fiduciari $SA_1, \ldots, SA_n$. La scelta di una Scrutiny Authority frammentata evita che una singola componente possieda da sola il potere di decifrare le schede. Lo scrutinio richiede quindi la cooperazione di almeno k nodi su n, secondo una soglia $\langle k, n \rangle$ definita nei parametri pubblici dell'elezione.

Ruolo. La Scrutiny Authority svolge le seguenti funzioni principali:

- rende disponibile la chiave pubblica elettorale pk_{SA}, usata dal Voting Client per cifrare la preferenza;
- mantiene la chiave privata di scrutinio in forma frammentata tra i nodi fiduciari;
- dopo la chiusura delle urne, recupera dal Registro Elettorale le schede cifrate;
- verifica che i voti da scrutinare corrispondano ai record presenti nel Registro Elettorale;
- produce frammenti di decifratura, senza ricostruire integralmente la chiave privata presso un singolo nodo;
- calcola il risultato finale e pubblica le informazioni necessarie alla verifica.

Chiavi. La Scrutiny Authority dispone di una chiave pubblica elettorale pk_{SA}, pubblicata nei parametri dell'elezione e usata dal Voting Client per cifrare la preferenza. La corrispondente chiave privata di scrutinio sk_{SA} non viene gestita come segreto posseduto da una singola entità, ma è rappresentata da frammenti distribuiti tra i nodi fiduciari della Scrutiny Authority.

Ciascun nodo fiduciario SA_i possiede inoltre una propria coppia di chiavi infrastrutturali (pk_{SA_i}, sk_{SA_i}), certificata dalla Government Authority. Tali chiavi servono ad autenticare il nodo e a firmare eventuali messaggi o frammenti prodotti durante la fase di scrutinio.

Dati che conosce e gestisce. Durante il protocollo, la Scrutiny Authority può conoscere i propri certificati, $Params_{Election}$, $CRL_{Election}$, l'insieme delle schede cifrate presenti nel Registro Elettorale, i record pubblici necessari alla verifica, i frammenti di decifratura, le preferenze decifrate durante lo scrutinio e il risultato aggregato finale.

Dati che non deve conoscere. La Scrutiny Authority non deve conoscere l'identità reale degli elettori, i token di autorizzazione associati alle identità reali e le informazioni usate dalla Government Authority per verificare l'idoneità al voto. Essa può partecipare alla decifratura delle schede ai fini del conteggio, ma non deve essere in grado di associare una preferenza decifrata a uno specifico elettore.

1.4 Primitive crittografiche adottate

Questa sezione riassume le primitive crittografiche utilizzate nel protocollo e il loro ruolo operativo. L'obiettivo non è descrivere la teoria delle primitive, ma chiarire in quali punti della soluzione esse vengono applicate e quali proprietà supportano.

Primitiva	**Uso nel protocollo**	**Proprietà supportate**
Firma digitale	La Government Authority firma certificati, token di autorizzazione, manifesto dell'elezione e liste di revoca. Il Registro Elettorale può firmare record, ricevute o stati del registro. I nodi della Scrutiny Authority possono firmare i contributi prodotti durante lo scrutinio.	Autenticità, integrità, non ripudio operativo degli oggetti pubblicati.
Certificati digitali e PKI	I certificati emessi dalla Government Authority associano una chiave pubblica a un'identità infrastrutturale, a un ruolo e a una specifica elezione. Sono usati per validare Voting Server, Registro Elettorale e nodi fiduciari della Scrutiny Authority.	Distribuzione autenticata delle chiavi pubbliche, mitigazione di sostituzione di chiave e impersonificazione.
Cifratura asimmetrica	Il Voting Client cifra la preferenza usando la chiave pubblica elettorale pk_{SA}. In questo modo Voting Server e Registro Elettorale trattano solo schede cifrate. La cifratura può inoltre essere usata per proteggere il token quando viene consegnato al destinatario previsto.	Segretezza della preferenza, separazione tra raccolta e scrutinio.
Funzioni hash	Gli hash sono usati per calcolare impronte di schede cifrate, record del Bulletin Board, radici Merkle o hash pointer. Sono inoltre usati dal Voting Server per registrare riferimenti non invertibili ai token spesi.	Integrità, rilevazione di alterazioni, supporto alla verificabilità individuale e universale.
MAC e autenticazione del canale	Nei canali sicuri di comunicazione, i MAC o meccanismi equivalenti di autenticazione dei messaggi sono usati per rilevare modifiche ai messaggi in transito. La sola cifratura del canale non viene considerata sufficiente a garantire integrità.	Integrità e autenticazione dei messaggi di sessione.
Nonce e timestamp	Nonce e timestamp sono utilizzati nei messaggi di autenticazione, richiesta token e sessione per legare le risposte al contesto corrente e ridurre il rischio di replay.	Freschezza, protezione da riuso e replay.
Chiavi di sessione	Quando due entità comunicano attraverso un canale sicuro, viene stabilita una chiave simmetrica di sessione, indicata come $k_{session}$. Da essa possono essere derivate sotto-chiavi per cifratura e autenticazione del canale.	Confidenzialità e integrità efficiente delle comunicazioni.

Primitiva	Uso nel protocollo	Proprietà supportate
Frammentazione della chiave di scrutinio	La chiave privata di scrutinio associata a pk_{SA} non viene gestita da una singola entità, ma distribuita tra i nodi fiduciari della Scrutiny Authority sotto forma di frammenti $Share_i$. Lo scrutinio richiede la cooperazione di almeno k nodi su n.	Riduzione del singolo punto di fiducia nella fase di scrutinio.

Le primitive vengono quindi usate in modo complementare: la cifratura protegge la segretezza della preferenza, le firme digitali e i certificati supportano autenticità e distribuzione fidata delle chiavi pubbliche, gli hash rendono verificabili i dati pubblicati, mentre i meccanismi di autenticazione del canale proteggono i messaggi in transito. La soluzione evita di assumere che una singola primitiva garantisca tutte le proprietà di sicurezza.

1.5 Setup iniziale e infrastruttura di fiducia

Prima dell'apertura dell'elezione, la Government Authority prepara l'infrastruttura di fiducia necessaria all'esecuzione del protocollo. Questa fase stabilisce quali entità infrastrutturali possono partecipare alla consultazione, quali chiavi pubbliche sono considerate valide, quali certificati sono accettati e quali parametri pubblici definiscono l'istanza elettorale.

Il setup comprende la generazione delle chiavi infrastrutturali, l'accreditamento delle entità operative, l'emissione dei certificati, la preparazione della Scrutiny Authority distribuita, la pubblicazione del manifesto dell'elezione e la gestione della lista di revoca. Al termine di questa fase, Voting Client, Voting Server, Registro Elettorale e nodi fiduciari della Scrutiny Authority dispongono delle informazioni necessarie per riconoscere le entità legittime e utilizzare chiavi pubbliche autentiche.

1.5.1 Premessa sui canali di comunicazione sicuri

Le comunicazioni sensibili del protocollo avvengono su canali autenticati, cifrati e integri. Nel documento, il canale sicuro viene considerato come uno strato di comunicazione basato su certificati, verifica delle chiavi pubbliche, chiavi di sessione e meccanismi di autenticazione dei messaggi.

Prima di inviare dati sensibili a un'entità infrastrutturale, il mittente verifica:

- che il certificato del destinatario sia firmato dalla Government Authority;
- che il certificato sia valido per $ID_{Election}$;
- che il ruolo indicato nel certificato sia coerente con l'operazione richiesta;
- che il certificato non compaia in $CRL_{Election}$;
- che la sessione utilizzi valori freschi, come nonce o timestamp, per ridurre il rischio di replay.

Il dettaglio del key exchange viene trattato come parte dello strato di comunicazione sicura. Nelle fasi operative del protocollo verrà indicato quando il Voting Client deve aprire tale canale e quali garanzie deve ottenere: autenticazione dell'entità remota, confidenzialità, integrità e freschezza della sessione.

1.5.2 Generazione delle chiavi infrastrutturali

Ogni entità infrastrutturale partecipante genera autonomamente una propria coppia di chiavi asimmetriche. In particolare, generano una coppia di chiavi il Voting Server, il Registro Elettorale/Bulletin Board e ciascun nodo fiduciario SA_i della Scrutiny Authority distribuita.

Per una generica entità X, la coppia di chiavi viene indicata come:

$$(pk_X, sk_X).$$

La chiave pubblica pk_X viene inserita nella richiesta di accreditamento e, in caso di approvazione, nel certificato digitale emesso dalla Government Authority. La chiave privata sk_X rimane sotto il controllo dell'entità e viene usata per dimostrare il possesso della chiave pubblica corrispondente, autenticarsi nelle comunicazioni e firmare i messaggi prodotti nelle fasi successive del protocollo.

Il certificato dell'entità viene emesso e firmato dalla Government Authority tramite sk_{GA}. La firma dell'entità sulla richiesta di accreditamento serve invece come prova di possesso della chiave privata associata alla chiave pubblica da certificare.

1.5.3 Preparazione della Scrutiny Authority distribuita

La Scrutiny Authority è composta da un insieme di nodi fiduciari:

$$SA = \{SA_1, SA_2, \ldots, SA_n\}.$$

Prima dell'apertura dell'elezione viene fissata una soglia di cooperazione $\langle k, n \rangle$, dove n è il numero totale dei nodi fiduciari e k è il numero minimo di nodi necessari per completare lo scrutinio.

La chiave pubblica elettorale pk_{SA} viene pubblicata nei parametri dell'elezione e sarà usata dal Voting Client per cifrare la preferenza. La chiave privata di scrutinio associata a pk_{SA} è gestita in forma frammentata tramite i valori $Share_i$, assegnati ai nodi fiduciari SA_i.

Il protocollo utilizza questa organizzazione per ridurre il singolo punto di fiducia nella fase di scrutinio. Ai fini della soluzione proposta, si richiede che:

- ogni nodo SA_i sia accreditato e certificato dalla Government Authority;
- la soglia $\langle k, n \rangle$ sia pubblicata in $Params_{Election}$;
- nessun singolo nodo possa decifrare autonomamente le schede;
- durante lo scrutinio almeno k nodi cooperino per produrre il risultato finale.

1.5.4 Richiesta di accreditamento

Il processo di accreditamento stabilisce quali componenti sono autorizzate a partecipare all'elezione e con quale ruolo. Le entità candidate, come Voting Server, Registro Elettorale e nodi fiduciari della Scrutiny Authority, inviano alla Government Authority una richiesta di certificazione.

La richiesta di accreditamento di una generica entità X è rappresentata logicamente come:

$$RequestCert_X = (ID_X, Role_X, ID_{Election}, pk_X, OrganizationInfo_X, ValidFrom, ValidTo, Nonce_X, \sigma_X$$

I campi principali hanno il seguente significato:

- ID_X: identificativo pubblico dell'entità candidata;
- $Role_X$: ruolo operativo richiesto, ad esempio VS, ER oppure SA_i;
- $ID_{Election}$: identificativo dell'elezione per cui si richiede l'accreditamento;
- pk_X: chiave pubblica oggetto della certificazione;
- $OrganizationInfo_X$: informazioni amministrative sull'organizzazione o sull'infrastruttura che gestisce l'entità;
- $ValidFrom, ValidTo$: finestra temporale di validità richiesta;
- $Nonce_X$: valore casuale monouso usato per garantire freschezza della richiesta;
- σ_X: firma digitale prodotta con sk_X sui campi precedenti.

La firma della richiesta viene calcolata come:

$$\sigma_X = Sign_{sk_X}(H(ID_X \parallel Role_X \parallel ID_{Election} \parallel pk_X \parallel OrganizationInfo_X \parallel ValidFrom \parallel ValidTo \parallel N$$

Questa firma dimostra che l'entità che richiede il certificato possiede la chiave privata associata a pk_X.

1.5.5 Verifica della richiesta da parte della Government Authority

Ricevuta la richiesta, la Government Authority esegue i controlli necessari prima di autorizzare l'emissione del certificato. La verifica include almeno:

- controllo della presenza di ID_X nel registro $EligibleEntitiesDB$;
- controllo della coerenza tra $Role_X$ e il ruolo ammesso per l'entità candidata;
- controllo della corrispondenza con $ID_{Election}$;
- verifica della firma σ_X tramite pk_X, per accertare il possesso della chiave privata;
- controllo della finestra temporale $ValidFrom, ValidTo$;
- controllo della completezza e coerenza delle informazioni organizzative.

Se almeno uno dei controlli fallisce, la richiesta viene rifiutata e l'entità non può operare nel protocollo per quella specifica elezione. Se tutti i controlli hanno esito positivo, la Government Authority procede con l'emissione del certificato.

1.5.6 Emissione dei certificati

Per ogni entità accreditata, la Government Authority emette un certificato digitale che lega la chiave pubblica al ruolo operativo e all'istanza elettorale. Il certificato di una generica entità X è rappresentato come:

$$Cert_X = (ID_X, Role_X, ID_{Election}, pk_X, ValidFrom, ValidTo, SerialNumber_X, \sigma_{GA}^{Cert_X}).$$

La firma della Government Authority è calcolata sul contenuto del certificato esclusa la firma stessa:

$$\sigma_{GA}^{Cert_X} = Sign_{sk_{GA}}(H(ID_X \parallel Role_X \parallel ID_{Election} \parallel pk_X \parallel ValidFrom \parallel ValidTo \parallel SerialNumber_X)).$$

I certificati principali prodotti in questa fase sono:

- $Cert_{VS}$, relativo al Voting Server;
- $Cert_{ER}$, relativo al Registro Elettorale/Bulletin Board;
- $Cert_{SA_i}$, relativo al nodo fiduciario SA_i della Scrutiny Authority.

Il certificato è un oggetto pubblico: può essere mostrato alle altre componenti dell'infrastruttura per dimostrare che la chiave pubblica dell'entità è stata approvata dalla Government Authority. L'entità che riceve il certificato può verificarne l'autenticità applicando la chiave pubblica della Government Authority:

$$Verify_{pk_{GA}}(Cert_X, \sigma_{GA}^{Cert_X}) = TRUE.$$

La Government Authority conserva una copia dei certificati emessi e del relativo stato, così da poter gestire successivamente eventuali revoche.

1.5.7 Pubblicazione del manifesto dell'elezione

Completato l'accreditamento delle entità, la Government Authority pubblica il manifesto dell'elezione, indicato come $Params_{Election}$. Il manifesto rappresenta lo stato comune della consultazione e consente a Voting Client, Voting Server, Registro Elettorale e nodi della Scrutiny Authority di riferirsi alla stessa istanza elettorale.

Una possibile rappresentazione logica è:

$$\begin{aligned} Params_{Election} = (&ID_{Election}, ElectionType, Options, TimeOpen, TimeClose, \\ &Cert_{VS}, Cert_{ER}, \{Cert_{SA_i}\}_{i=1}^{n}, pk_{SA}, \langle k, n \rangle, \\ &H(Policy), Version, Timestamp, \sigma_{GA}^{Params}) \end{aligned}$$

dove:

$$\sigma_{GA}^{Params} = Sign_{sk_{GA}}(H(ID_{Election} \parallel ElectionType \parallel Options \parallel TimeOpen \parallel TimeClose \parallel Cert_{VS} \parallel Cert_{ER} \parallel \{Cert_{SA_i}\}_{i=1}^{n} \parallel pk_{SA} \parallel \langle k, n \rangle \parallel H(Policy) \parallel Version \parallel Timestamp)).$$

I campi principali del manifesto sono:

- $ID_{Election}$: identificativo univoco dell'elezione;
- $ElectionType$: tipo di consultazione;
- $Options$: insieme delle opzioni ammesse, nel caso base $\{\text{Sì}, \text{No}\}$;
- $TimeOpen, TimeClose$: istanti di apertura e chiusura della votazione;
- $Cert_{VS}, Cert_{ER}, \{Cert_{SA_i}\}_{i=1}^{n}$: certificati delle entità operative accreditate;
- pk_{SA}: chiave pubblica elettorale usata per cifrare la preferenza;
- $\langle k, n \rangle$: parametri della Scrutiny Authority distribuita;
- $H(Policy)$: digest delle regole operative dell'elezione;
- $Version, Timestamp$: versione e istante di pubblicazione del manifesto;
- σ_{GA}^{Params}: firma della Government Authority sul manifesto.

Il Voting Client e le altre entità infrastrutturali verificano la firma della Government Authority prima di utilizzare $Params_{Election}$. Inoltre, controllano che i certificati contenuti nel manifesto siano coerenti con i ruoli previsti e che non risultino revocati.

1.5.8 Pubblicazione e aggiornamento della lista di revoca

La Government Authority mantiene e pubblica la lista dei certificati revocati, indicata come $CRL_{Election}$. La lista contiene i numeri seriali dei certificati che non devono più essere accettati per l'elezione corrente, ad esempio in caso di compromissione della chiave privata o rimozione dell'entità dall'infrastruttura accreditata.

La lista di revoca è rappresentata come:

$$CRL_{Election} = (ID_{Election}, RevokedSerialNumbers, Version_{CRL}, Timestamp_{CRL}, NextUpdate, \sigma_{GA}^{CRL}).$$

La firma della Government Authority è calcolata come:

$$\sigma_{GA}^{CRL} = Sign_{sk_{GA}}(H(ID_{Election} \parallel RevokedSerialNumbers \parallel Version_{CRL} \parallel Timestamp_{CRL} \parallel NextUpd$$

I campi principali hanno il seguente significato:

- $ID_{Election}$: associa la lista di revoca all'elezione corrente;
- $RevokedSerialNumbers$: insieme dei numeri seriali dei certificati revocati;
- $Version_{CRL}$: versione della lista, usata per rilevare configurazioni obsolete;
- $Timestamp_{CRL}$: istante di emissione della lista;
- $NextUpdate$: istante entro cui deve essere disponibile una versione aggiornata;
- σ_{GA}^{CRL}: firma della Government Authority sulla lista.

Prima di accettare un certificato, una componente verifica la firma della CRL, controlla che la lista sia riferita a $ID_{Election}$, verifica che la versione sia aggiornata e controlla che il seriale del certificato non compaia in $RevokedSerialNumbers$.

La soluzione adotta un comportamento di tipo hard-fail: se una componente non riesce a recuperare o verificare una versione valida e aggiornata di $CRL_{Election}$, il certificato non viene accettato e l'operazione viene interrotta. Questa scelta privilegia la sicurezza rispetto alla disponibilità del servizio.

1.5.9 Revoca dell'accreditamento

La revoca dell'accreditamento permette alla Government Authority di invalidare un certificato precedentemente emesso. La revoca può avvenire su richiesta dell'entità interessata, ad esempio in caso di sospetta compromissione della chiave privata, oppure d'ufficio, se la Government Authority rileva che una componente non deve più partecipare al protocollo.

Nel caso di richiesta volontaria, l'entità invia alla Government Authority un messaggio contenente almeno l'identificativo dell'elezione, il numero seriale del certificato da revocare, una motivazione e un timestamp:

$$RevocationRequest_X = (ID_{Election}, SerialNumber_X, Reason_X, Timestamp_X, \sigma_X^{Rev}).$$

La firma σ_X^{Rev} viene prodotta con la chiave privata dell'entità:

$$\sigma_X^{Rev} = Sign_{sk_X}(H(ID_{Election} \parallel SerialNumber_X \parallel Reason_X \parallel Timestamp_X)).$$

La Government Authority verifica la richiesta, controlla che il certificato sia stato effettivamente emesso per l'entità indicata e aggiorna lo stato del certificato nei propri registri interni.

Nel caso di revoca d'ufficio, la Government Authority aggiorna direttamente lo stato del certificato associato all'entità, utilizzando le informazioni conservate durante la fase di accreditamento. In entrambi i casi, la revoca diventa operativa tramite la pubblicazione di una nuova versione di $CRL_{Election}$, con $Version_{CRL}$ incrementata e firma aggiornata.

Al termine del setup, l'infrastruttura dispone di entità accreditate, certificati verificabili, parametri pubblici firmati e una lista di revoca controllabile. Da questo momento il protocollo può passare alle fasi operative di autenticazione dell'elettore, rilascio del token e raccolta della scheda cifrata.

1.6 Flusso generale del protocollo

Dopo il completamento del setup iniziale, il protocollo entra nella fase operativa dell'elezione. In questa fase l'elettore usa il Voting Client per autenticarsi, ottenere un token di autorizzazione, compilare la scheda, inviare il voto cifrato e ricevere una ricevuta utile alla verifica di inclusione.

Il flusso complessivo può essere riassunto come segue:

Fase	Nome	Descrizione sintetica
1	Inizializzazione del Voting Client	Il client recupera e verifica i parametri pubblici dell'elezione, la lista di revoca e i certificati delle entità operative.
2	Autenticazione dell'elettore	L'elettore viene autenticato dalla Government Authority tramite il modulo di identità digitale.
3	Verifica di idoneità e rilascio del token	La Government Authority verifica il diritto al voto e rilascia un token di autorizzazione firmato.
4	Preparazione locale della scheda	Il Voting Client acquisisce la preferenza, cifra la scheda con pk_{SA} e prepara la busta di voto.
5	Apertura del canale sicuro verso il Voting Server	Il client verifica $Cert_{VS}$, controlla la CRL e stabilisce un canale autenticato, cifrato e integro.
6	Invio e verifica della busta di voto	Il Voting Server verifica token, prova di possesso e unicità del voto.
7	Pubblicazione sul Registro Elettorale	Il Voting Server inoltra la scheda cifrata al Registro Elettorale/Bulletin Board, che pubblica il record e produce una ricevuta.
8	Scrutinio finale	Alla chiusura delle urne, la Scrutiny Authority distribuita coopera per decifrare e conteggiare le schede accettate.
9	Pubblicazione e verifica	Vengono pubblicati risultato, record finali e dati necessari alla verificabilità individuale e universale.

Le fasi sono descritte assumendo che le parti oneste seguano il protocollo. Eventuali deviazioni, compromissioni o comportamenti malevoli vengono considerate nell'analisi di sicurezza.

1.7 Fase 1: inizializzazione del Voting Client

Quando l'elettore apre l'applicazione ufficiale, il Voting Client inizializza il contesto locale dell'elezione. Il client recupera $Params_{Election}$ e $CRL_{Election}$, quindi verifica che entrambi siano firmati dalla Government Authority.

La verifica dei parametri pubblici avviene controllando la firma:

$$Verify_{pk_{GA}}(Params_{Election}, \sigma_{GA}^{Params}) = TRUE.$$

Analogamente, il client verifica la lista di revoca:

$$Verify_{pk_{GA}}(CRL_{Election}, \sigma_{GA}^{CRL}) = TRUE.$$

Il Voting Client controlla poi che:

- $ID_{Election}$ corrisponda all'elezione selezionata;
- la consultazione sia all'interno della finestra temporale ammessa;
- i certificati $Cert_{VS}$, $Cert_{ER}$ e $\{Cert_{SA_i}\}_{i=1}^{n}$ siano coerenti con i ruoli dichiarati;
- nessuno dei certificati operativi compaia in $CRL_{Election}$;
- la chiave pubblica elettorale pk_{SA} sia presente nel manifesto firmato.

Successivamente, il client genera o recupera la coppia di chiavi dell'elettore per la specifica elezione:

$$(pk_U, sk_U).$$

La coppia (pk_U, sk_U) è associata a $ID_{Election}$. La chiave pubblica pk_U sarà usata per vincolare il token di autorizzazione al client dell'elettore, mentre sk_U rimane sotto il controllo dell'utente e non viene trasmessa.

1.8 Fase 2: autenticazione dell'elettore

Dopo l'inizializzazione, l'elettore avvia la procedura di autenticazione presso la Government Authority. Questa fase è svolta dal modulo IP, che verifica l'identità reale dell'utente secondo il meccanismo di identità digitale previsto dal sistema.

Il Voting Client invia alla Government Authority una richiesta di autenticazione contenente l'identificativo dell'elezione, la chiave pubblica generata per l'elezione e valori di freschezza della sessione:

$$AuthRequest_U = (ID_{Election}, pk_U, nonce_U, timestamp_U).$$

Il modulo IP autentica l'elettore e produce un'asserzione di autenticazione, firmata dalla Government Authority:

$$AuthAssertion_U = (ID_U, ID_{Election}, pk_U, nonce_U, timestamp_{GA}, \sigma_{GA}^{Auth}).$$

La firma σ_{GA}^{Auth} è calcolata sui campi dell'asserzione:

$$\sigma_{GA}^{Auth} = Sign_{sk_{GA}}(H(ID_U \parallel ID_{Election} \parallel pk_U \parallel nonce_U \parallel timestamp_{GA})).$$

Questa fase stabilisce l'identità reale dell'elettore nei confronti della Government Authority. Non implica ancora il rilascio del diritto al voto: l'autenticazione viene seguita dalla verifica dell'idoneità elettorale.

1.9 Fase 3: verifica dell'idoneità e rilascio del token

Ricevuta l'asserzione di autenticazione, il modulo EV della Government Authority verifica che l'elettore autenticato sia presente in $EligibleUsersDB$ e sia abilitato a partecipare alla consultazione identificata da $ID_{Election}$.

Se la verifica fallisce, il protocollo termina senza emissione del token. Se la verifica ha esito positivo, il modulo VTI genera un permesso di voto:

$$Permit_U = (ID_{Election}, SerialNumber_{Token}, pk_U, ValidFrom, ValidTo).$$

Il permesso contiene l'identificativo dell'elezione, un numero seriale univoco del token, la chiave pubblica dell'elettore e una finestra temporale di validità. Non contiene la preferenza dell'elettore.

La Government Authority firma il permesso:

$$\sigma_{GA}^{Permit} = Sign_{sk_{GA}}(H(ID_{Election} \parallel SerialNumber_{Token} \parallel pk_U \parallel ValidFrom \parallel ValidTo)).$$

Il token di autorizzazione è quindi:

$$VotingToken_U = (Permit_U, \sigma_{GA}^{Permit}).$$

Per consegnare il token al Voting Client, la Government Authority può cifrarlo usando la chiave pubblica dell'elettore:

$$EncToken_U = Enc_{pk_U}(VotingToken_U).$$

Il Voting Client recupera il token decifrando localmente:

$$VotingToken_U = Dec_{sk_U}(EncToken_U).$$

La Government Authority aggiorna $IssuedTokensDB$, registrando che per l'elettore autenticato è stato emesso un token per $ID_{Election}$. Questa registrazione serve a impedire l'emissione di più token per lo stesso elettore nella medesima elezione.

1.10 Fase 4: preparazione locale della scheda

Dopo aver ottenuto il token, il Voting Client mostra all'elettore le opzioni ammesse dalla consultazione, contenute in $Params_{Election}$. Nel caso base del referendum binario:

$$Options = \{\text{Sì}, \text{No}\}.$$

L'elettore seleziona una preferenza:

$$v \in Options.$$

Il Voting Client genera un valore casuale $nonce_{ballot}$, usato per legare la scheda a una specifica esecuzione locale del protocollo, e costruisce il contenuto logico del voto:

$$VotePlain_U = (ID_{Election}, v, nonce_{ballot}).$$

La preferenza viene cifrata con la chiave pubblica elettorale della Scrutiny Authority:

$$EncVoto_{SA} = Enc_{pk_{SA}}(VotePlain_U).$$

Da questo momento, Voting Server e Registro Elettorale trattano solo la scheda cifrata. La preferenza in chiaro rimane disponibile nel Voting Client solo durante la compilazione locale e deve essere eliminata dalla memoria non appena non risulta più necessaria.

Il client prepara inoltre una firma di possesso della chiave privata associata al token:

$$\sigma_U^{Ballot} = Sign_{sk_U}(H(ID_{Election} \parallel EncVoto_{SA} \parallel SerialNumber_{Token} \parallel nonce_{ballot})).$$

Questa firma consente al Voting Server di verificare che chi presenta il token possieda la chiave privata corrispondente a pk_U, presente nel permesso firmato dalla Government Authority.

1.11 Fase 5: verifica del Voting Server e apertura del canale sicuro

Prima di trasmettere la busta di voto al Voting Server, il Voting Client deve verificare che il destinatario sia effettivamente un'entità autorizzata per l'elezione corrente. Questa fase non riguarda l'autenticazione dell'elettore, già avvenuta presso la Government Authority durante il rilascio del token, ma l'autenticazione dell'entità infrastrutturale incaricata di ricevere le richieste di voto.

Il Voting Client utilizza $Params_{Election}$ e $CRL_{Election}$, pubblicati e firmati dalla Government Authority. In particolare, recupera il certificato del Voting Server $Cert_{VS}$ e verifica che esso sia stato emesso dalla Government Authority:

$$Verify_{pk_{GA}}(Cert_{VS}, \sigma_{GA}^{Cert_{VS}}) = TRUE.$$

Il client controlla inoltre che il certificato:

- sia valido per l'elezione identificata da $ID_{Election}$;

- sia associato al ruolo di Voting Server;
- non sia scaduto;
- non compaia in $CRL_{Election}$.

Questa verifica realizza il binding tra identità infrastrutturale, ruolo operativo e chiave pubblica. Il Voting Client accetta pk_{VS} solo se tale chiave è contenuta in un certificato valido e firmato dalla Government Authority. In questo modo, la chiave pubblica del server non viene assunta come affidabile perché ricevuta dalla rete, ma perché certificata dall'autorità responsabile dell'infrastruttura elettorale.

Superata la verifica, il Voting Client estrae dal certificato la chiave pubblica del Voting Server:

$$Cert_{VS} \longrightarrow pk_{VS}.$$

A questo punto il Voting Client apre un canale sicuro autenticato con il Voting Server:

$$VC \leftrightarrow VS : \text{SecureChannel}(Cert_{VS}, ID_{Election}).$$

Il canale deve garantire autenticazione del server, confidenzialità dei messaggi, integrità dei dati trasmessi e freschezza della sessione. La freschezza può essere ottenuta tramite nonce, timestamp o valori casuali di sessione, così da evitare il riutilizzo di messaggi appartenenti a sessioni precedenti.

Dal punto di vista operativo, il canale sicuro può essere realizzato mediante un key exchange autenticato basato su Diffie-Hellman. In tale scambio, Voting Client e Voting Server contribuiscono entrambi alla derivazione di un segreto condiviso di sessione; tuttavia, i valori pubblici usati nello scambio non vengono accettati in modo cieco. Durante l'apertura del canale sicuro, il Voting Server dimostra di essere il titolare della chiave pubblica contenuta in $Cert_{VS}$. In particolare, il server usa la propria chiave privata sk_{VS} per autenticare lo scambio di sessione. Poiché il Voting Client ha già verificato che $Cert_{VS}$ sia stato firmato dalla Government Authority, che non sia revocato e che sia valido per $ID_{Election}$, il client può accettare la chiave di sessione derivata come chiave condivisa con il Voting Server autorizzato. In questo modo, il key exchange produce una chiave simmetrica associata al server certificato per l'elezione corrente:

$$k_{session}.$$

La chiave $k_{session}$ viene usata dallo strato di comunicazione sicura per proteggere i messaggi successivi tra Voting Client e Voting Server. Ai fini del protocollo di voto, è sufficiente assumere che il canale stabilito fornisca:

$$\text{autenticazione del server} \wedge \text{confidenzialità} \wedge \text{integrità} \wedge \text{freschezza}.$$

Terminata questa fase, il Voting Client dispone di un canale sicuro verso un Voting Server autenticato per $ID_{Election}$. Solo a questo punto il client trasmette la busta di voto contenente il token di autorizzazione e la scheda cifrata.

1.12 Fase 6: invio della busta di voto e verifica del token

Il Voting Client costruisce la busta logica di voto:

$$Ballot = (ID_{Election}, EncVoto_{SA}, VotingToken_U, \sigma_U^{Ballot}, nonce_{ballot}).$$

Il messaggio viene inviato al Voting Server attraverso il canale sicuro stabilito nella fase precedente:

$$M_{vote} : VC \rightarrow VS : Ballot.$$

Il Voting Server esegue i controlli necessari prima di accettare la scheda:

- verifica che $ID_{Election}$ corrisponda all'elezione corrente;
- verifica la firma della Government Authority sul token;
- controlla la validità temporale di $Permit_U$;
- estrae pk_U dal permesso firmato;
- verifica σ_U^{Ballot} usando pk_U;
- controlla che il token non sia già stato usato;
- verifica la freschezza del messaggio tramite $nonce_{ballot}$ e $timestamp_{ballot}$.

La verifica della firma della Government Authority sul token è:

$$Verify_{pk_{GA}}(Permit_U, \sigma_{GA}^{Permit}) = TRUE.$$

La verifica della prova di possesso della chiave dell'elettore, serve ad assicurarsi che il Token all'interno del Ballot sia stato utilizzato dall'effettivo richiedente dell'autorizzazione al voto. Questo perchè, a partire dalla generazione delle chiavi pubbliche e private da parte del client, l'autorizzazione al voto rilasciata dalla GA è firmata dalla suddetta e contiene anche la chiave pubblica dell'utente che la richiede. La verifica viene effettuata in questo modo:

$$Verify_{pk_U}(ID_{Election} \parallel EncVoto_{SA} \parallel SerialNumber_{Token} \parallel nonce_{ballot}, \sigma_U^{Ballot}) = TRUE.$$

Se almeno uno dei controlli fallisce, il Voting Server rifiuta la busta di voto. Se tutti i controlli hanno esito positivo, il server procede con la registrazione del token come utilizzato.

1.13 Fase 7: registrazione del token speso

Per garantire l'unicità del voto, il Voting Server deve impedire il riutilizzo dello stesso token di autorizzazione. Il server non conserva il token completo in chiaro all'interno

di $SpentTokensDB$, ma memorizza un riferimento non invertibile derivato dal numero seriale del token.

Il server calcola un sale dinamico deterministico:

$$Salt_i = H(K_{Master_Server} \parallel ID_{Election} \parallel SerialNumber_{Token}).$$

Successivamente calcola il digest da inserire nel registro dei token spesi:

$$Hash_{Spent} = H(SerialNumber_{Token} \parallel Salt_i).$$

Il valore $Hash_{Spent}$ viene cercato in $SpentTokensDB$. Se il digest è già presente, il token è considerato già utilizzato e la busta di voto viene rifiutata. Se il digest non è presente, il Voting Server registra $Hash_{Spent}$ e accetta la scheda cifrata per la pubblicazione.

Il sale deve essere derivato in modo deterministico a partire dal numero seriale del token e da un segreto interno del server. In questo modo, lo stesso token produce sempre lo stesso digest di controllo, consentendo al Voting Server di rilevare tentativi di riuso senza memorizzare direttamente il token.

1.14 Fase 8: pubblicazione sul Registro Elettorale / Bulletin Board

Dopo aver accettato la busta di voto e registrato il token come speso, il Voting Server inoltra al Registro Elettorale/Bulletin Board solo la scheda cifrata e i metadati necessari alla registrazione pubblica. Il token di autorizzazione non viene pubblicato sul registro, in modo da ridurre il rischio di correlazione tra autorizzazione al voto e scheda registrata.

Il payload del messaggio inviato dal Voting Server al Registro Elettorale è:

$$M_{VS} = (ID_{Election}, EncVoto_{SA}, timestamp_{VS}).$$

Il Voting Server firma tale payload:

$$\sigma^M_{VS} = Sign_{sk_{VS}}(H(M_{VS})).$$

Il messaggio inviato al Registro Elettorale è quindi:

$$M_{board} : VS \rightarrow ER : (M_{VS}, \sigma^M_{VS}).$$

Il Registro Elettorale verifica la firma del Voting Server tramite il certificato $Cert_{VS}$, controllando che il certificato sia valido, riferito a $ID_{Election}$, associato al ruolo di Voting Server e non revocato in $CRL_{Election}$.

Se la verifica ha esito positivo, il Registro inserisce M_{Board} nella propria Bulletin Board append-only, assegnandogli una posizione pubblica i ed un timestamp che certifica l'inserimento in un istante preciso:

$$BoardRecord_i = (i, M_{Board}, timestamp_{ER}).$$

Oltre all'inserimento all'interno della Bulletin Board, il Registro Elettorale utilizza una struttura ad albero binario Merkle-based. Ciò viene fatto per fornire all'utente una Proof of Membership (prova di inclusione del proprio voto all'interno del registro) alla fine dell'elezione. In particolare, per ogni $BoardRecord_i$ calcola una foglia associata:

$$Leaf_i = H(BoardRecord_i).$$

E viene inserita all'interno dell'albero.

Durante la fase di voto, la struttura del Merkle Tree può cambiare a seguito dell'inserimento di nuove schede. Per questo motivo, la ricevuta immediata non contiene un Merkle path definitivo, ma solamente un riferimento alla scheda cifrata accettata.

$$Receipt_U = (ID_{Election}, Leaf_i, timestamp_{ER}, \sigma_{ER}^{Receipt}).$$

La firma del Registro Elettorale è calcolata come:

$$\sigma_{ER}^{Receipt} = Sign_{sk_{ER}}\Big(H(ID_{Election} \parallel Leaf_i \parallel timestamp_{ER})\Big).$$

La ricevuta consente all'elettore di conservare una prova di avvenuta ricezione del voto da parte del Registro Elettorale, ma non costituisce una Proof of Membership in quanto il Merkle Tree durante lo svolgimento dell'elezione ha una radice non definitiva. Alla chiusura dell'elezione, quando il Bulletin Board viene cristallizzato, il Registro Elettorale pubblica la radice finale $Root_{final}$ firmata dal Registro Elettorale, l'elenco definitivo dei record e, per ciascuna foglia, il relativo Merkle path definitivo, così che l'utente potrà verificare con la Bulletin Board l'avvenuta ricezione del voto e con il Merkle Path e la sua foglia potrà verificare l'inclusione del proprio voto.

L'elettore verifica quindi:

1. la firma del Registro Elettorale sulla ricevuta $\sigma_{ER}^{Receipt}$;
2. la presenza della propria foglia $Leaf_i$ nel Bulletin Board finale;
3. la correttezza del Merkle path definitivo associato a $Leaf_i$ rispetto a $Root_{final}$;
4. la firma del Registro Elettorale sulla radice finale pubblicata.

Questa procedura fornisce una prova di inclusione della scheda cifrata nel registro pubblico, senza rivelare la preferenza in chiaro. La ricevuta non elimina completamente i rischi di coercizione tipici del voto remoto, poiché un elettore potrebbe comunque mostrare a terzi le informazioni ricevute dal sistema. Per questo motivo, essa viene interpretata come prova di inclusione della scheda cifrata, non come prova pubblica della preferenza espressa.

1.15 Fase 9: chiusura delle urne e scrutinio finale

Alla chiusura della finestra temporale di voto, il Registro Elettorale cristallizza l'insieme delle schede cifrate accettate. Da questo momento non vengono più accettati nuovi record per l'elezione corrente.

Il Registro Elettorale pubblica lo stato finale del Bulletin Board, includendo la radice finale della struttura di inclusione:

$$Root_{final}.$$

L'insieme dei record pubblicati viene reso disponibile alla Scrutiny Authority:

$$\{BoardRecord_i\}_{i=1}^{m}.$$

La Scrutiny Authority distribuita verifica che le schede da scrutinare corrispondano ai record pubblicati nel Bulletin Board. Successivamente, almeno k nodi fiduciari su n producono i rispettivi contributi di decifratura:

$$DecShare_i = PartialDec_{Share_i}(EncVoto_{SA}).$$

Ogni nodo SA_i firma il proprio contributo:

$$\sigma_{SA_i}^{DecShare} = Sign_{sk_{SA_i}}(H(DecShare_i \parallel ID_{Election})).$$

I contributi validi vengono combinati per ottenere le preferenze da conteggiare. Il risultato finale viene calcolato aggregando le preferenze decifrate e verificando che il numero di schede scrutinate corrisponda al numero di schede cifrate accettate nel Bulletin Board.

1.16 Fase 10: pubblicazione del risultato e verificabilità

Terminato lo scrutinio, viene pubblicato il risultato finale dell'elezione insieme alle informazioni necessarie alla verifica. La pubblicazione finale può includere:

- $ID_{Election}$;
- $Root_{final}$;
- numero totale di schede accettate;
- risultato aggregato;
- lista dei record pubblicati o relativi hash;
- firme dei nodi della Scrutiny Authority sui contributi prodotti;
- firma finale della Scrutiny Authority o dei nodi partecipanti.

1.16.1 Verificabilità individuale

L'elettore utilizza $Receipt_U$ per verificare che la propria scheda cifrata sia inclusa nel Bulletin Board finale. In particolare, controlla che il valore $Leaf_i$ contenuto nella ricevuta compaia nella struttura pubblicata e sia coerente con $Root_{final}$.

Questa verifica permette all'elettore di controllare l'inclusione della propria scheda cifrata, senza rivelare la preferenza espressa.

1.16.2 Verificabilità universale

La verificabilità universale consente a osservatori esterni di controllare la coerenza pubblica del risultato. Un verificatore può controllare che:

- i record pubblicati siano coerenti con $Root_{final}$;
- ogni scheda scrutinata corrisponda a una scheda cifrata pubblicata;
- il numero di schede scrutinate coincida con il numero di schede accettate;
- i contributi dei nodi della Scrutiny Authority siano firmati da nodi certificati;
- il risultato aggregato corrisponda alle schede decifrate.

La verificabilità universale non richiede la conoscenza dell'identità reale degli elettori. Essa si basa sulla pubblicazione dei record cifrati, delle prove di inclusione e dei dati di scrutinio necessari a controllare la coerenza tra Bulletin Board e risultato finale.